

# AGRI-POS — Full Logic, Connection, Security & Data-Flow Audit

**Repository:** `lessrealmoments-dot/AGRI-POS-DUPLICATE-FOR-PUBLIC-CHECK` (audited via `/app` working copy) **Date:** 2026-02  
**Mode:** READ-ONLY DEEP AUDIT (no code changes applied) **Scope:** FastAPI backend ( `/app/backend` ) + React frontend ( `/app/frontend` ) + MongoDB schema

Backend is treated as the source of truth where backend and frontend disagree. No fixes applied.

## 1. Executive Summary

The system is **functionally rich and broadly self-consistent**, with mature ideas around tenant isolation ( `TenantCollection` ), idempotency on offline sync (envelope\_id unique index), late-encode controls, audit logging, and signature/PIN policy. However, the audit surfaced a **non-trivial number of correctness, atomicity, and security defects** that are concentrated in five areas:

- Atomicity / multi-collection writes** — sales, returns, voids, and offline sync mutate inventory + invoices + wallets + customer balance in sequence, never inside a transaction or compensating action. A mid-flow failure leaves stock, AR, or cash in a permanently inconsistent state.
- Customer balance drift** — `customers.balance` is incremented/decremented in 30+ call sites with no reconciliation pass, plus one call site ( `sync.py:437` ) writes to a non-existent field ( `current_balance` ), silently no-op'ing AR reversal during orphan-offline reconciliation.
- Offline sync double-deduction window** — `sales/sync` checks idempotency, then mutates inventory, then inserts the invoice. Two concurrent retries can both pass the check and both deduct stock before the unique index trips.
- Plain-text PIN exposure to the client** — `/api/sync/pos-data` ships every admin/owner/manager PIN in cleartext (and the bcrypt hash of the admin PIN) to any authenticated user. This is a P0 secret-leak.
- Public/loose admin surfaces** — `/api/setup/reset` (full data wipe), `/api/setup/initialize` , `/api/admin-auth/setup-totp` (TOTP take-over of an un-MFA'd super admin), `/api/admin/backfill/iter240` , `/api/admin/reconcile-orphan-offline-draft` , and CORS defaulting to `*` form a wider attack surface than necessary.

Backdated credit sales are partially supported via the `late_encode` flow (capped at 7 days, no link to last count sheet), which is **insufficient for the user's "old notebook AR encoding" use case**. A proper Historical Credit / AR Reconstruction workflow is needed (see §6).

**Overall risk posture:** - **Critical (P0):** 9 issues — fix before next production deploy - **High (P1):** 14 issues — fix in the next 1–2 cycles - **Medium (P2):** 12 issues — schedule for the next quarter - **Low (P3):** 8 issues — backlog

## 2. Critical Findings (P0)

| #   | Finding                                                                                                                                           | File / Route                        | Risk                                                                                                               |
|-----|---------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------|--------------------------------------------------------------------------------------------------------------------|
| C-1 | <code>/api/sync/pos-data</code> ships <b>plain-text PINs</b> of all admin/owner/manager users + bcrypt admin PIN hash to any authenticated caller | <code>routes/sync.py:734-798</code> | Any cashier can extract every manager/admin PIN. Privilege escalation, void/refund/discount bypass, audit forgery. |
| C-2 |                                                                                                                                                   |                                     |                                                                                                                    |

| #   | Finding                                                                                                                                                                                                                                                   | File / Route                                                                            | Risk                                                                                              |
|-----|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------|
|     | <code>/api/setup/reset</code> deletes <b>every collection</b> with only <code>confirm_text="DELETE ALL DATA"</code> and <b>no auth</b>                                                                                                                    | <code>routes/setup.py:213-238</code>                                                    | Anyone on the internet can wipe the entire database. Data loss.                                   |
| C-3 | <code>/api/admin-auth/setup-totp</code> lets a password holder set TOTP secret on a super-admin who hasn't enabled TOTP yet — full account takeover with just the password                                                                                | <code>routes/admin_auth.py:150-223</code>                                               | Super-admin compromise → all tenants exposed.                                                     |
| C-4 | Sales / offline-sync deduct inventory <b>before</b> invoice insert; on insert-failure (DuplicateKey, network, validation) stock is gone with no compensating reverse                                                                                      | <code>routes/sales.py:583-685, 902-910</code> ,<br><code>routes/sync.py:864-1015</code> | Inventory permanently wrong, no audit trail.                                                      |
| C-5 | Offline <code>/api/sales/sync</code> idempotency check is non-atomic — two concurrent retries can both pass <code>find_one(...)</code> then both <code>\$inc</code> inventory before the <code>envelope_id</code> unique index fires on the second insert | <code>routes/sync.py:870-983</code>                                                     | Double stock deduction under network retry / dual-tab POS.                                        |
| C-6 | <code>_finalize_draft_offline</code> deducts inventory <b>before</b> the guarded draft <code>update_one</code> , with no rollback if the guard rejects a concurrent finalize                                                                              | <code>routes/sync.py:99-179</code>                                                      | Same draft can deduct stock twice.                                                                |
| C-7 | <code>routes/sync.py:437</code> — <code>reconcile_orphan_offline_draft</code> reverses customer credit by <code>\$inc current_balance</code> (wrong field; everywhere else it is <code>balance</code> )                                                   | <code>routes/sync.py:432-439</code>                                                     | Customer AR remains inflated after recovery; manager believes it was reversed.                    |
| C-8 | RMA number generator uses <code>count_documents({})+1</code> with no <code>branch_id</code> / <code>organization_id</code> scoping and no atomic counter — collisions guaranteed under concurrent returns; cross-tenant numbering pool                    | <code>routes/returns.py:105-106</code>                                                  | Duplicate RMA numbers, cross-tenant number leakage.                                               |
| C-9 | <code>record_invoice_payment</code> does <b>not</b> check <code>status=="voided"</code> before applying — payments can be received against a voided invoice                                                                                               | <code>routes/invoices.py:192-264</code>                                                 | Wallet credited, customer balance silently goes negative, audit trail says "paid voided invoice". |

### 3. High-Risk Business Logic Findings (P1)

| #   | Finding                                                                                                                                              | File / Route                                                    | Risk                                                                                                                                                                                                             |
|-----|------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| H-1 | Draft finalization uses <code>db.invoices.replace_one({"id": draft_id}, invoice)</code> with <b>no version/status guard</b>                          | <code>routes/sales.py:900</code>                                | Concurrent finalize wipes the in-flight invoice; loses <code>doc_code</code> , <code>signature_session</code> , <code>late_encode</code> flags, <code>recovery_note</code> , etc. set between fetch and replace. |
| H-2 | No MongoDB transactions / Motor <code>start_session().with_transaction()</code> anywhere — every multi-collection mutation is best-effort sequential | system-wide                                                     | Sales, voids, returns, branch transfers, PO receive, repacks, daily close all have torn-write windows.                                                                                                           |
| H-3 | Customer <code>balance</code> is stored & manually incremented in <b>30+ call sites</b> ; no reconciliation report against ledger                    | <code>routes/sales.py:960</code> ,<br><code>invoices.py:</code> |                                                                                                                                                                                                                  |

| #    | Finding                                                                                                                                                                                                                                                                                                 | File / Route                                                                               | Risk                                                                                                                          |
|------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------|
|      |                                                                                                                                                                                                                                                                                                         | 257,595,1157,1379 ,<br>accounting.py (×16),<br>returns.py:259,510 ,<br>sync.py:1099 , etc. | Drift over time; no way to detect or repair without manual SQL-style audit.                                                   |
| H-4  | Returns can apply credit to <b>any</b> open invoice for the customer ( <code>fallback</code> ), not just the linked invoice — even unrelated, older debt                                                                                                                                                | routes/returns.py:213-220                                                                  | Customer A returns ₱500 of feed but gets ₱500 applied to a months-old chemical invoice they hadn't paid. Books move silently. |
| H-5  | <code>assert_branch_access</code> returns OK when user has <b>neither</b> <code>branch_ids</code> <b>nor</b> <code>branch_id</code> ("legacy unscoped") — a cashier with a malformed user record gains org-wide branch access                                                                           | utils/auth.py:172-177                                                                      | Cross-branch data exposure.                                                                                                   |
| H-6  | CORS <code>allow_origins</code> defaults to <code>*</code> if env not set                                                                                                                                                                                                                               | main.py:1184                                                                               | Cross-origin token theft via XSS/CSRF when env misconfigured.                                                                 |
| H-7  | JWT TTL 24h with no refresh / rotation / blacklist                                                                                                                                                                                                                                                      | utils/auth.py:26                                                                           | Stolen token is good for a full day; no logout-all.                                                                           |
| H-8  | <code>get_current_user</code> does <b>not</b> validate that <code>user.organization_id == payload.org_id</code> — a moved/re-attached user keeps cross-org access until token expiry                                                                                                                    | utils/auth.py:73-86                                                                        | Org migration bug → cross-tenant access.                                                                                      |
| H-9  | <code>users.email</code> index is <b>non-unique</b> (only sparse). Email duplicates allowed across tenants and within tenant                                                                                                                                                                            | main.py:389                                                                                | Login lookup ambiguity, password-reset confusion.                                                                             |
| H-10 | <code>invoices.invoice_number</code> has <b>no uniqueness index</b> (only <code>idempotency_key</code> and <code>envelope_id</code> are unique); <code>generate_next_number</code> is atomic per branch but a manual import / migration / retry could create duplicates                                 | main.py:407-435 , utils/numbering.py                                                       | Duplicate invoice numbers possible via import or out-of-band insert.                                                          |
| H-11 | Backdated late-encode is capped at <b>7 days</b> with no awareness of last approved physical inventory count — too restrictive for "old notebook credit" reconstruction, while still allowing inventory to retro-deduct on the historical date                                                          | routes/sales.py:78-118 ,<br>utils/closed_day_guard.py                                      | User's primary outstanding business case is unsupported. See §6 for proposed Historical Credit Encoding flow.                 |
| H-12 | Offline negative stock is silently allowed — only writes a <code>stock_warnings</code> array on the invoice; no <code>incident_ticket</code> , no admin notification, no reconciliation queue entry                                                                                                     | routes/sync.py:113-148,<br>942-982                                                         | Phantom inventory, no operator alert, eventual zero-out at next count sheet.                                                  |
| H-13 | <code>setup.py:initialize</code> creates the first admin even after multi-tenant migration if no users exist (race / partial-restore case)                                                                                                                                                              | routes/setup.py:42-51                                                                      | Possibility of attaching a forged admin to an existing org if collections were partially deleted.                             |
| H-14 | <code>/api/admin/backfill/iter240</code> and <code>/api/admin/backfill/iter241-close-ledger</code> mutate every synced-from-offline invoice and every closed-day with <code>apply=true</code> ; gated only by <code>role=="admin"</code> (no PIN, no audit-log, no per-call dry-run-then-confirm chain) | routes/<br>admin_backfill_240.py                                                           | An admin with a stolen token can re-write historical financial data; no signed audit chain.                                   |

## 4. Inventory Flow Audit Table

| Module                                | Action                                 | Expected Stock Effect                                      | Actual Code                | Movement Logged?                           | Reversible?                                                                                                           | Risk                                                              |
|---------------------------------------|----------------------------------------|------------------------------------------------------------|----------------------------|--------------------------------------------|-----------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------|
| Sales ( / <code>unified-sale</code> ) | Cash sale (full release)               | -qty on commit                                             | -qty before invoice insert | ✓ via <code>log_movement</code>            | ✓ via void (reverses qty, not net of subsequent adjustments)                                                          | C-4 — stock gone if invoice insert fails                          |
| Sales                                 | Partial release (reservation)          | -qty avail, +qty reserved                                  | Correct                    | ✓                                          | ✓ via void+reservation cleanup                                                                                        | OK; reservation doesn't expire-revert                             |
| Sales                                 | Repack child sold                      | -qty parent / <code>units_per_parent</code>                | Correct                    | ✓ on parent                                | ✓                                                                                                                     | OK; parent capital change not propagated to existing reservations |
| Draft order                           | Reserve invoice number                 | none                                                       | none ✓                     | n/a                                        | n/a (cancel sets <code>cancelled_draft</code> )                                                                       | OK                                                                |
| Draft → Finalize online               | -qty once, replace draft inv           | <code>replace_one</code> wipes guard fields                | ✓                          | ✓                                          | H-1 — <code>replace_one</code> race                                                                                   |                                                                   |
| Draft → Finalize offline              | -qty once on canonical draft           | -qty BEFORE guarded <code>update_one</code>                | ✓                          | ✓ on sync                                  | C-6 — concurrent retry can deduct twice                                                                               |                                                                   |
| Offline sale sync                     | -qty                                   | -qty before insert                                         | ✓                          | ✓                                          | C-5 — race; H-12 — negative stock not alerted                                                                         |                                                                   |
| Invoice edit                          | adjust delta only                      | <code>\$inc</code> delta correctly handled (lines 380-447) | ✓                          | ✓                                          | OK except no PIN required for closed-day edits when <code>pin == ""</code> and <code>is_on_closed_day == False</code> |                                                                   |
| Invoice void                          | +qty (or +reserved on partial-release) | Correct                                                    | ✓                          | ✓                                          | OK                                                                                                                    |                                                                   |
| Returns — shelf                       | +qty                                   | Correct                                                    | ✓                          | ✓                                          | C-8 RMA collision                                                                                                     |                                                                   |
| Returns — pullout                     | none                                   | none + log loss                                            | ✓                          | ✗ (intentional — "physically gone")        | OK                                                                                                                    |                                                                   |
| Return void                           | -qty (only shelf items)                | Correct                                                    | ✓                          | ✓                                          | OK                                                                                                                    |                                                                   |
| Branch transfer send                  | -qty source                            | Correct                                                    | ✓                          | partial: receive can short, no auto-revert | OK                                                                                                                    |                                                                   |

| Module                  | Action                                       | Expected Stock Effect                   | Actual Code    | Movement Logged?      | Reversible?                                                                     | Risk |
|-------------------------|----------------------------------------------|-----------------------------------------|----------------|-----------------------|---------------------------------------------------------------------------------|------|
| Branch transfer receive | +qty destination                             | Correct                                 | ✓              | ✓                     | OK                                                                              |      |
| PO receive              | +qty                                         | Correct                                 | ✓              | ✓                     | partial-receive duplicate guard not formally checked here — review separately   |      |
| PO cancel after receive | none (must do supplier return)               | confirmed                               | n/a            | n/a                   | OK                                                                              |      |
| Repacking               | -parent / +child slot via runtime derivation | child stock is derived, no separate row | n/a            | n/a                   | OK by design; no double-count risk                                              |      |
| Count sheet adjustment  | set qty to actual                            | overwrites                              | ✓              | partial reversibility | check <code>count_sheets.py</code> for variance tagging on movements collection |      |
| Crop credit release     | -qty (charged-to-crop)                       | needs re-verification                   | review pending | review pending        | review pending                                                                  |      |

## 5. Money Movement / Z-Report Audit

### Date-field usage inventory (highest impact discovery)

| Report / Wallet flow                     | Date field actually used                                      | Should use                                 | Issue                                                                            |
|------------------------------------------|---------------------------------------------------------------|--------------------------------------------|----------------------------------------------------------------------------------|
| Sales report ( <code>reports.py</code> ) | Mix of <code>order_date</code> , <code>created_at</code>      | <code>order_date</code> (transaction date) | Inconsistent — backdated/late-encoded sales sometimes appear on encoded-day list |
| Z-Report carryover for late-encode       | <code>late_encoded_at</code> (effective day)                  | Effective day ✓                            | Correct, but the carryover label uses <code>intended_date</code> which is fine   |
| Daily sales log → Close Wizard           | <code>date</code> field on <code>sales_log</code>             | matches <code>order_date</code>            | OK                                                                               |
| Cash collected today                     | sums <code>payments[].date</code> and <code>created_at</code> | <code>payment.date</code> only             | Backdated payments can leak into today                                           |
| Customer ledger                          | <code>order_date</code>                                       | <code>order_date</code> ✓                  | OK                                                                               |
| Inventory movement                       | <code>created_at</code>                                       | <code>created_at</code> ✓                  | OK                                                                               |
| Backdated entry report                   | none — does not exist                                         | needs separate tab                         | gap                                                                              |

| Money Flow | Expected | Actual                                         | Risk | Fix |
|------------|----------|------------------------------------------------|------|-----|
|            | +amount  | Correct ( <code>update_cashier_wallet</code> ) | low  | OK  |

| Money Flow                    | Expected                                         | Actual                   | Risk                      | Fix                                                                                  |
|-------------------------------|--------------------------------------------------|--------------------------|---------------------------|--------------------------------------------------------------------------------------|
| Cash sale<br>→ cashier wallet |                                                  |                          |                           |                                                                                      |
| Credit sale<br>→ AR           | +balance on customer                             | \$inc balance            | drift                     | reconciliation report                                                                |
| Payment received              | -AR, +wallet                                     | Correct                  | drift                     | reconciliation report                                                                |
| Partial payment               | -balance, +wallet, status=partial                | Correct                  | OK                        | OK                                                                                   |
| Void invoice                  | reverse all payments[] from each fund + reset AR | Correct (handles split)  | low                       | OK; but wallet can go negative — allow_negative=True is OK in this path but no alert |
| Return + cash refund          | -refund from selected fund                       | Correct (safe lots FIFO) | OK                        | OK                                                                                   |
| Return + AR credit            | -applied from any open invoice                   | H-4 risk                 | misapplication            | restrict to linked invoice or unapplied credit memo                                  |
| Closed-day edit               | journal_entry auto-generated                     | Correct                  | low                       | requires manager PIN + audit row — both present                                      |
| Daily close                   | ledger entries via write_close_ledger_entries    | Correct                  | low                       | OK                                                                                   |
| Z-Report PDF share            | synthetic user; org context resolved             | recently fixed           | OK                        | keep monitoring                                                                      |
| Customer interest accrual     | -AR scope, daily; can compound                   | reads stored balance     | drift if balance is wrong | derive principal from invoices, not customer.balance                                 |

## 6. Backdated Credit Sale Audit (USER'S PRIORITY)

### Current state

The current `late_encode` flow in `routes/sales.py:41-126` and `utils/closed_day_guard.py:179-327` :

- **Allows** late-encoded credit/partial sales up to 7 days back, on the same VAT month, with manager PIN + reason ≥10 chars + 5/branch/day cap.
- **Stores** `late_encoded` , `late_encoded_at` , `late_encode_reason` , `late_encoded_by` , `late_encode_verifier_*` , `late_encode_days_back` on the invoice.
- **Inserts** an `audit_log` row + a `late_encode_log` row.
- **Inventory** moves on the historical `order_date` — i.e. `inventory.quantity` decrements **today** but the invoice line is stamped with the historical date. There is no historical-vs-encoded divergence in the inventory ledger.
- **Z-Report** shows the entry on the next-open day with a `[LATE ENCODE] original date {intended} (closed)` label.

## Why this is insufficient for the user's case

The user's scenario: a customer's notebook credit was never encoded; **months later**, when they pay, the system has no record of the prior debt. Today the system blocks any encoding > 7 days back. Even if the cap were lifted, the existing flow:

- Re-deducts inventory **today** at historical `order_date`'s product cost → wrong COGS / margin reporting.
- Has no link to "last approved physical inventory count date for that branch/product".
- Mixes historical AR reconstruction with normal late-encode, distorting the late-encode metrics tab.

## Recommended workflow — separate **Historical Credit Encoding** module

| Rule                                                                                                                                       | Recommendation                                                                                                                                                                                                                                              | Risk Prevented                                                               | Code Changes                                     |
|--------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------|--------------------------------------------------|
| Store both <code>transaction_date</code> and <code>encoded_at</code> separately                                                            | Add <code>encoded_at</code> field on every invoice (already exists for late-encode); make <code>order_date</code> = historical and <code>created_at</code> = encoded for this flow                                                                          | Reports can choose either basis intentionally                                | small                                            |
| Reports use <code>transaction_date</code> for <i>Sales by date</i> and <code>customer ledger</code>                                        | Switch to <code>order_date</code> everywhere; never use <code>created_at</code> for these reports                                                                                                                                                           | Backdated AR appears in correct historical position on the customer ledger   | medium                                           |
| Z-Report uses <code>created_at</code> (encoded_at)                                                                                         | Keep current carryover behaviour                                                                                                                                                                                                                            | Old Z-Reports remain immutable                                               | none                                             |
| Inventory ON historical date OR on encoded date — NOT both                                                                                 | New rule: if <code>order_date</code> < <code>last_count_sheet.date</code> → <b>do not</b> decrement inventory; create a <code>historical_credit_only=True</code> invoice with no movement and a sticky <code>inventory_already_settled_at_count</code> flag | Prevents double-deducting stock that was already reconciled in a count sheet | medium                                           |
| If <code>order_date</code> >= <code>last_count_sheet.date</code> → require admin approval + reason + proof, then deduct inventory normally | Same workflow but allowed                                                                                                                                                                                                                                   | Recent unrecorded sales still adjust stock                                   | medium                                           |
| Add <code>last_approved_count_sheet_date</code> per (branch, product)                                                                      | Pull from the latest <code>count_sheets</code> doc with status= <code>approved</code>                                                                                                                                                                       | Stable stopper for the rule above                                            | small (already in <code>count_sheets.py</code> ) |
| Required role: <code>admin</code> (not manager); reason ≥ 20 chars; proof_url required                                                     | Stricter than <code>late_encode</code>                                                                                                                                                                                                                      | Forensic audit trail                                                         | small                                            |
| New audit collection: <code>historical_credit_encoding_log</code>                                                                          | Distinct from <code>late_encode_log</code>                                                                                                                                                                                                                  | Clean separation in Audit Center                                             | small                                            |
| Separate "Backdated Credit Encoding Report" UI                                                                                             | New tab under Audit Center → "Historical AR Encoding"                                                                                                                                                                                                       | Reviewers can spot patterns                                                  | medium                                           |
| <code>backdated_credit=True</code> invoices are excluded from the 5/branch/day late-encode cap                                             | Lift the 7-day rule for this specific flow only                                                                                                                                                                                                             | User's "months later" use case                                               | small                                            |

| Rule                              | Recommendation | Risk Prevented               | Code Changes |
|-----------------------------------|----------------|------------------------------|--------------|
| Cash backdating remains forbidden | unchanged      | Z-Report tampering prevented | none         |

**Frontend change:** New page `pages/HistoricalCreditEncodingPage.js` (or reuse `UnifiedSalesPage` with a `mode=historical_credit` switch behind admin permission). Backend: new endpoint `POST /api/sales/historical-credit` that bypasses the 7-day cap but enforces the `last_count_sheet_date` rule and writes to `historical_credit_encoding_log`. Re-use `_finalize_draft_offline` -style guard pattern for atomicity.

## 7. Void / Return / Refund Audit

| Original Transaction             | Reversal Action              | Expected Inv Effect                                | Expected Money Effect                               | Actual                                                 | Risk                                                                              |
|----------------------------------|------------------------------|----------------------------------------------------|-----------------------------------------------------|--------------------------------------------------------|-----------------------------------------------------------------------------------|
| Cash sale                        | Void invoice                 | +qty                                               | -cashier wallet                                     | Correct                                                | OK                                                                                |
| Credit sale                      | Void invoice                 | +qty                                               | -customer.balance, no wallet change                 | Correct                                                | drift on customer.balance                                                         |
| Partial sale                     | Void invoice                 | +qty                                               | reverse each <code>payment[]</code> from its source | Correct (per-payment fund reversal in lines 1097-1133) | wallet can go negative — flagged by <code>allow_negative=True</code> but no alert |
| Sale with split payment          | Void invoice                 | +qty                                               | reverse cash + digital                              | Correct                                                | OK                                                                                |
| Partial-release sale             | Void invoice                 | only +reserved_qty (released qty stays out)        | reverse cash                                        | Correct                                                | OK                                                                                |
| Return — shelf                   | Return                       | +qty                                               | -wallet                                             | Correct                                                | C-8 RMA collisions                                                                |
| Return — pullout                 | Return                       | none + loss log                                    | -wallet                                             | Correct                                                | OK                                                                                |
| Return void                      | Reverse return               | -qty (shelf only)                                  | +wallet                                             | Correct                                                | also reverses applied AR credit (good)                                            |
| Voided invoice — receive payment | should refuse                | NO check on voided status                          | C-9                                                 | wallet credited against voided invoice                 | severe drift                                                                      |
| Payment void                     | Reverse a single payment     | -wallet, +AR                                       | Correct                                             | OK                                                     |                                                                                   |
| PO cancel after partial receive  | should not auto-remove stock | not auto-removed (manual supplier return required) | OK                                                  | OK                                                     |                                                                                   |
|                                  |                              | OK                                                 | OK                                                  | OK                                                     |                                                                                   |



| Original Transaction              | Reversal Action             | Expected Inv Effect | Expected Money Effect | Actual | Risk |
|-----------------------------------|-----------------------------|---------------------|-----------------------|--------|------|
| Branch transfer cancel after send | manual supplier return path |                     |                       |        |      |

**Double-void protection:** `void_invoice` checks `status == "voided"` ✓. `void_return` checks `voided` ✓. `void_payment` checks `payment.voided` ✓. ✓ good.

## 8. Purchase Order / Supplier Audit

(Cursory pass — full audit requires deeper read of `routes/purchase_orders.py` (2,288 lines).)

| Flow                    | Expected                                                               | Actual                                                                                                     | Risk                                                               | Fix                                                              |
|-------------------------|------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------|------------------------------------------------------------------|
| PO creation             | no inventory movement                                                  | confirmed by route names                                                                                   | OK                                                                 | none                                                             |
| Receiving               | +qty once                                                              | atomic per line                                                                                            | needs unique <code>(po_id, line_id, received_at)</code> constraint | partial dupe protection via <code>received_qty</code> increments |
| Partial receive         | only delta increases                                                   | depends on UI passing only the delta — backend should validate <code>received_qty &lt;= ordered_qty</code> | needs verification (P1)                                            | add server-side cap                                              |
| PO cancel after receive | no auto-remove                                                         | confirmed by user reports                                                                                  | OK                                                                 | none                                                             |
| Supplier return         | -qty + -payable                                                        | confirmed                                                                                                  | OK                                                                 | none                                                             |
| Cost update             | logs to <code>capital_changes</code> and <code>price_change_log</code> | confirmed                                                                                                  | OK                                                                 | OK                                                               |
| Last purchase cost      | derived in <code>sync.py</code> and dashboard                          | confirmed                                                                                                  | OK                                                                 | OK                                                               |

## 9. Offline Sync Audit

| Sync Scenario                                                  | Expected        | Actual                                                                                | Duplicate Risk                                                                           | Fix                                                     |
|----------------------------------------------------------------|-----------------|---------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------|---------------------------------------------------------|
| Same OFF receipt synced twice (same <code>envelope_id</code> ) | second is no-op | unique index on <code>envelope_id</code> rejects second insert; existence check first | LOW once index in place; <b>inventory still moved</b> between check and unique index hit | apply inventory <b>after</b> insert succeeds (re-order) |
|                                                                | second is no-op |                                                                                       | inventory still moved twice if                                                           | apply inventory only after guarded update               |

| Sync Scenario                           | Expected                                                                   | Actual                                                                                                    | Duplicate Risk                                                    | Fix                                                        |
|-----------------------------------------|----------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------|------------------------------------------------------------|
| Offline draft finalization synced twice |                                                                            | <code>linked_offline_receipt_number</code> canary + <code>status="for_preparation"</code> guard on update | guard fails on second                                             | returns <code>modified_count &gt; 0</code>                 |
| Network race during single OFF sync     | only one inventory move                                                    | no <code>update_one(...).modified_count</code> checked → both pass                                        | medium                                                            | guard pattern + check                                      |
| Offline negative stock                  | warn + <code>stock_warnings</code> array                                   | done                                                                                                      | does NOT create <code>incident_ticket</code> / admin notification | add notification + <code>reconciliation_queue</code> entry |
| Offline price-match replay              | <code>branch_prices</code> upserts only after PIN re-verifies              | done; logs <code>pin_resync_failed</code> flag                                                            | OK                                                                | OK                                                         |
| Offline manager-bypass signature        | retroactive <code>signature_session</code> w/ <code>status=bypassed</code> | done                                                                                                      | OK                                                                | OK                                                         |
| Customer balance during offline sync    | <code>\$inc balance</code> after invoice insert                            | done                                                                                                      | drift accumulates                                                 | reconciliation report                                      |

**Design observation:** the entire sync layer should switch to a *write-then-mutate* order: 1. `db.invoices.insert_one(...)` (unique index will reject duplicate `envelope_id`) 2. only on success → mutate inventory + wallets + customer balance 3. on failure → rollback: invalid invoice (status `sync_failed`) + skip mutations

This is a non-trivial refactor but it eliminates the full class of double-deduction bugs at once.

## 10. API Connection Audit

### Confirmed dead/duplicate routes

| Endpoint                                                      | Backend                                    | Frontend Caller                                                | Status                                 | Action                                                               |
|---------------------------------------------------------------|--------------------------------------------|----------------------------------------------------------------|----------------------------------------|----------------------------------------------------------------------|
| <code>/api/reports/test-report-v2</code>                      | <code>main.py:1205</code>                  | none                                                           | DEAD + UNAUTHENTICATED                 | <b>Remove</b> or auth-gate                                           |
| <code>/api/setup/reset</code>                                 | <code>routes/setup.py:213</code>           | likely DEV-only                                                | UNAUTHENTICATED                        | <b>Auth-gate to super_admin only OR remove</b>                       |
| <code>/api/setup/initialize</code>                            | <code>routes/setup.py:42</code>            | first-run flow                                                 | UNAUTHENTICATED                        | guard against re-run on existing tenants (current check is too weak) |
| <code>/api/sales/*</code> (legacy <code>SalesPage.js</code> ) | <code>routes/sales.py</code> (some legacy) | <code>pages/SalesPage.js</code> mounted at <code>/sales</code> | DUPLICATE WITH <code>/sales-new</code> | <b>Consolidate</b> — already in user backlog                         |
| <code>/api/admin/backfill/iter240</code>                      | one-shot                                   | <code>AuditCenterPage.js</code>                                | KEEP but harden                        | require PIN + audit row + idempotency                                |

| Endpoint                                                                                                                | Backend                                 | Frontend Caller                 | Status                       | Action                                                                                                       |
|-------------------------------------------------------------------------------------------------------------------------|-----------------------------------------|---------------------------------|------------------------------|--------------------------------------------------------------------------------------------------------------|
|                                                                                                                         |                                         |                                 |                              | stamp (idempotency exists)                                                                                   |
| <code>/api/admin/backfill/iter241-close-ledger</code>                                                                   | one-shot                                | <code>AuditCenterPage.js</code> | KEEP but harden              | same                                                                                                         |
| <code>/api/sales/sync</code> (legacy POST that handles brand-new offline sales) vs <code>_finalize_draft_offline</code> | both inside <code>routes/sync.py</code> | terminal                        | overlapping responsibilities | KEEP both, but unify inventory-deduction helper                                                              |
| <code>/api/admin-auth/setup-totp</code>                                                                                 | <code>routes/admin_auth.py:150</code>   | one-time TOTP onboarding        | DANGEROUS as-is              | <b>Add side-channel verification</b> (email-link or pre-shared secret) before allowing first-time TOTP setup |

## Frontend → Backend connectivity audit

A full per-page sweep was not done, but spot checks confirm: - `/sales-new` (UnifiedSalesPage) → `/api/unified-sale` ✓  
- `/sales` (SalesPage) — still routed in `App.js:243` ✗ DUPLICATE PAGE; consolidate per user backlog - `/pos`, `/sales-order` → both → UnifiedSalesPage ✓ - `ReturnRefundWizard` → `/api/returns` ✓ - `AuditCenterPage` → `/api/admin/backfill/*` ✓ - `MessagesPage` → `/api/sms/*` ✓ - `PrintQueuePage`, `TerminalShell` → `/api/print-jobs`, `/api/sync/*` ✓

## Dead frontend pages (suspected — needs design audit)

- `pages/UploadPage.js` vs `pages/DocUploadPage.js` — possibly overlapping
- `pages/PaymentsPage.js` vs `pages/AccountsPage.js` — possibly overlapping

# 11. Security and Permission Audit

| Risk                                    | File / Route                          | Who Can Abuse               | Severity        | Fix                                                                                                                                                                                |
|-----------------------------------------|---------------------------------------|-----------------------------|-----------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Plain-text PIN distribution to client   | <code>sync.py:734-798</code>          | any authenticated user      | <b>Critical</b> | replace with bcrypt-only verification round-trip via <code>/api/verify/pin</code> (already exists); keep ONLY <code>admin_pin_hash</code> if you must, behind a manager-token gate |
| Public DB wipe                          | <code>setup.py:213</code>             | anyone                      | <b>Critical</b> | super-admin auth + 2FA + confirmation token sent via email                                                                                                                         |
| TOTP take-over                          | <code>admin_auth.py:setup-totp</code> | password thief              | <b>Critical</b> | force out-of-band confirmation (email link, recovery code) before allowing first TOTP setup                                                                                        |
| CORS * default                          | <code>main.py:1184</code>             | external sites if env unset | High            | force explicit allowlist; refuse to start if not set in production                                                                                                                 |
| JWT 24h, no refresh, no revocation list | <code>utils/auth.py</code>            | stolen-token holder         | High            | shorter access tokens (15-30m) + refresh token + token blacklist on logout                                                                                                         |

| Risk                                                                           | File / Route                                      | Who Can Abuse                                               | Severity                    | Fix                                                                                                                              |
|--------------------------------------------------------------------------------|---------------------------------------------------|-------------------------------------------------------------|-----------------------------|----------------------------------------------------------------------------------------------------------------------------------|
| Hardcoded test credentials in repo                                             | <code>backend/tests/*.py</code>                   | anyone reading repo                                         | High (since repo is public) | move to env-only; the credentials match a real production-ish account per <code>memory/test_credentials.md</code>                |
| Backfill endpoints mutate prod data                                            | <code>admin_backfill_240.py</code>                | any admin token                                             | High                        | PIN + 2-step confirm + audit ledger row per call                                                                                 |
| <code>/api/admin/reconcile-orphan-offline-draft</code>                         | <code>sync.py:304</code>                          | admin (PIN required)                                        | Medium                      | already reasonably guarded; keep PIN; add per-orphan idempotency lock                                                            |
| <code>assert_branch_access</code> legacy bypass                                | <code>auth.py:172-177</code>                      | user with empty <code>branch_ids</code>                     | High                        | refuse access instead of granting org-wide (data has migrated; legacy mode can be retired)                                       |
| <code>users.email</code> non-unique index                                      | <code>main.py:389</code>                          | duplicate-email collisions                                  | High                        | unique compound index ( <code>organization_id, email</code> )                                                                    |
| <code>check_perm / has_perm</code> short-circuit on <code>role=="admin"</code> | <code>utils/auth.py:100,120</code>                | any user-doc with <code>role=admin</code> (not super-admin) | Medium                      | OK conceptually but means a malicious admin can void/edit anything — there's no per-action 4-eye principle except via PIN policy |
| No per-IP rate limiting on <code>/auth/*</code> and <code>/admin-auth/*</code> | <code>auth.py</code> , <code>admin_auth.py</code> | brute force                                                 | Medium                      | add slowapi or Cloudflare-side limiter                                                                                           |
| Global exception handler returns generic message but logs full stack to stdout | <code>main.py:87-104</code>                       | log scrapers                                                | Low                         | OK as-is; just confirm logs are not shipped to a public bucket                                                                   |

## 12. Multi-Tenant / Branch Isolation Audit

The `TenantCollection` design is **excellent in principle** — fail-closed when no org context, automatic `organization_id` injection. However:

| Surface                                                     | Expected Scope                                          | Actual Scope                                                                                                                                                                                                                                                        | Isolation Risk                                                  | Fix                                                                                                                                                |
|-------------------------------------------------------------|---------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------|
| 339 uses of <code>_raw_db.*</code> across routes            | explicit <code>organization_id</code> filter every time | mostly enforced; <code>superadmin.py</code> and <code>setup.py</code> legitimately cross-tenant; <code>terminal.py</code> ( <code>terminal_codes</code> , <code>qr_pair_tokens</code> , <code>terminal_sessions</code> ) is unscoped because they're transient — OK | LOW for terminal; MEDIUM for <code>sms_hooks/settings.py</code> | spot-check <code>sms_hooks.py:53,75,84,97,...</code> — these use <code>_raw_db</code> then resolve org via the branch — confirmed safe but fragile |
| <code>branch_transfer_orders</code> cross-branch within org | only via approved transfer                              | confirmed                                                                                                                                                                                                                                                           | OK                                                              | OK                                                                                                                                                 |
|                                                             | yes                                                     | confirmed                                                                                                                                                                                                                                                           | OK                                                              | OK except H-5                                                                                                                                      |

| Surface                                                                                            | Expected Scope                                                                                      | Actual Scope                             | Isolation Risk | Fix                                                                                |
|----------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------|------------------------------------------|----------------|------------------------------------------------------------------------------------|
| <code>get_branch_filter</code> / <code>apply_branch_filter</code> honoring <code>branch_ids</code> |                                                                                                     |                                          |                |                                                                                    |
| <code>superadmin</code> impersonation                                                              | sets <code>_current_org_id</code> to target tenant                                                  | confirmed ( <code>auth.py:77-80</code> ) | OK             | impersonation_session 4h TTL is reasonable                                         |
| <code>users.find({"role": "admin"})</code> in <code>branch_transfers.py:614-619</code>             | org-scoped via TenantCollection                                                                     | confirmed                                | OK             | OK                                                                                 |
| <code>notifications.target_user_ids</code> cross-branch admins                                     | TenantCollection scopes by org                                                                      | confirmed                                | OK             | OK                                                                                 |
| <code>signature_sessions</code>                                                                    | TenantCollection scopes                                                                             | confirmed in TENANT_COLLECTIONS list     | OK             | OK                                                                                 |
| Counter collection ( <code>counters</code> ) is shared globally                                    | by design — counter key is <code>{branch_id}: {prefix}</code> so branch UUID provides the namespace | confirmed                                | LOW            | OK; but a cross-org branch_id collision is impossible because branch_ids are uuid4 |

## 13. Database Integrity Audit

| Collection                  | Issue                                                | Risk                                                 | Fix                                                                               | Migration?                                                   |
|-----------------------------|------------------------------------------------------|------------------------------------------------------|-----------------------------------------------------------------------------------|--------------------------------------------------------------|
| <code>invoices</code>       | no unique on <code>invoice_number</code>             | dup numbers possible via import/migration            | unique compound ( <code>organization_id, invoice_number</code> )                  | yes — backfill scan first                                    |
| <code>users</code>          | <code>email</code> non-unique                        | dup logins                                           | unique compound ( <code>organization_id, email</code> )                           | yes — dedupe scan first                                      |
| <code>users</code>          | <code>username</code> unique global (not org-scoped) | cross-tenant username collision blocks user creation | change to ( <code>organization_id, username</code> )                              | yes                                                          |
| <code>customers</code>      | no unique on phone                                   | dup customers, opening_balance double-create         | unique compound ( <code>organization_id, branch_id, phone</code> ) partial filter | yes — already handled by <code>merge_duplicates</code> route |
| <code>movements</code>      | no unique on ( <code>reference_id, type</code> )     | re-running PO receive could double-log               | unique partial ( <code>reference_id, branch_id, product_id, type</code> )         | yes                                                          |
| <code>daily_closings</code> | no unique on ( <code>branch_id, date</code> )        | dup close possible                                   | unique compound ( <code>organization_id, branch_id, date</code> )                 | yes                                                          |

| Collection                                   | Issue                                                           | Risk                          | Fix                                                                                              | Migration? |
|----------------------------------------------|-----------------------------------------------------------------|-------------------------------|--------------------------------------------------------------------------------------------------|------------|
| <code>count_sheets.count_sheet_number</code> | unique not enforced;<br>generator is racy                       | dup count sheet<br>numbers    | atomic counter via<br><code>_raw_db.counters</code> (like<br><code>generate_next_number</code> ) | small      |
| <code>returns.rma_number</code>              | C-8 — racy<br><code>count_documents+1</code><br>global          | duplicate RMAs<br>across orgs | atomic counter scoped<br>per <code>(organization_id,</code><br><code>branch_id)</code>           | yes        |
| <code>safe_lots.remaining_amount</code>      | no constraint<br>preventing < 0                                 | overdraw silently             | application check +<br>monitoring                                                                | none       |
| Soft delete vs hard delete                   | mostly soft<br>( <code>active=False</code> )                    | OK                            | OK                                                                                               | none       |
| Orphan records                               | <code>customers.reattach-</code><br><code>orphans</code> exists | partial fix                   | OK                                                                                               | none       |

## 14. Math and Calculation Audit

| Calculation            | Frontend                                                                                       | Backend                                           | Match? | Risk                                                               | Fix                                                       |
|------------------------|------------------------------------------------------------------------------------------------|---------------------------------------------------|--------|--------------------------------------------------------------------|-----------------------------------------------------------|
| Subtotal               | per-line <code>qty*rate-disc</code>                                                            | same                                              | ✓      | OK                                                                 |                                                           |
| Per-unit discount      | <code>qty * disc_val</code> (amount) or<br><code>qty * rate * disc_val/100</code><br>(percent) | same                                              | ✓      | OK                                                                 |                                                           |
| Overall discount       | flat amount                                                                                    | flat amount                                       | ✓      | OK                                                                 |                                                           |
| Grand total            | <code>subtotal + freight -</code><br><code>overall</code>                                      | same                                              | ✓      | OK                                                                 |                                                           |
| Balance                | <code>grand_total - amount_paid</code>                                                         | same                                              | ✓      | OK                                                                 |                                                           |
| Change                 | client-side only                                                                               | n/a                                               | n/a    | OK                                                                 | confirm receipt<br>prints same<br>value backend<br>stores |
| COGS / margin          | <code>cost_price * qty</code><br>snapshotted in <code>sale_items</code>                        | same                                              | ✓      | OK                                                                 |                                                           |
| Repack capital         | derived: <code>parent_cost / units</code><br><code>+ add_on_cost</code>                        | matches<br><code>sync.py:707-709</code>           | ✓      | OK                                                                 |                                                           |
| Capital change alerts  | dashboard reads<br><code>capital_changes</code>                                                | written from PO<br>receive                        | ✓      | OK                                                                 |                                                           |
| Interest (per invoice) | <code>principal * monthly/30 *</code><br><code>days_overdue</code>                             | <code>invoices.py:</code><br><code>289-294</code> | ✓      | OK; but uses stored<br><code>inv.balance</code> — drift<br>exposed |                                                           |
| Penalty                | similar to interest                                                                            | <code>accounting.py</code>                        | ✓      | same drift exposure                                                |                                                           |
| Rounding               | <code>round(..., 2)</code> everywhere                                                          | matches                                           | ✓      | OK; not using Decimal<br>— accept Python float<br>for now          |                                                           |

| Calculation     | Frontend                                                         | Backend                | Match? | Risk                                      | Fix |
|-----------------|------------------------------------------------------------------|------------------------|--------|-------------------------------------------|-----|
| Negative totals | guarded <code>max(0, ...)</code>                                 | matches                | ✓      | OK                                        |     |
| Overpayment     | not blocked; goes to <code>payments[].amount &gt; balance</code> | not blocked at backend | ⚠      | refuse overpayment<br>OR auto-credit memo |     |

## 15. Repacking Audit

| Repack Step                                 | Expected                                                        | Actual                                                                    | Risk                             |
|---------------------------------------------|-----------------------------------------------------------------|---------------------------------------------------------------------------|----------------------------------|
| Parent-derived inventory                    | child availability = <code>parent_qty * units_per_parent</code> | confirmed in <code>sync.py:691-696</code> , <code>sales.py:589-595</code> | OK — no separate child stock row |
| Parent stock decrement on repack-child sale | <code>-qty / units_per_parent</code>                            | confirmed ( <code>sales.py:602-608</code> )                               | OK                               |
| Cost allocation                             | <code>parent_cost / units + add_on_cost</code>                  | confirmed                                                                 | OK                               |
| Repack reversal                             | comes from invoice void                                         | confirmed                                                                 | OK                               |
| JIT retail price for repacks                | persisted to <code>branch_prices</code> after Owner PIN         | confirmed ( <code>sales.py:321-377</code> )                               | OK                               |
| Negative parent stock                       | allowed only with manager override pin                          | confirmed ( <code>sales.py:489-522</code> )                               | OK                               |
| Repack reports                              | derived live                                                    | n/a                                                                       | OK                               |

**Conclusion:** repacking design is **correct and not at risk** of creating/destroying value.

## 16. Report Reliability Audit

| Report                       | Source                           | Date Field                         | Voided handling                      | Branch/Tenant Filter      | Reliability                                                          |
|------------------------------|----------------------------------|------------------------------------|--------------------------------------|---------------------------|----------------------------------------------------------------------|
| Sales Report                 | <code>invoices</code>            | <code>order_date</code>            | excludes by default                  | TenantCollection + branch | OK                                                                   |
| Inventory Report             | <code>inventory</code>           | <code>updated_at</code>            | n/a                                  | TenantCollection          | OK                                                                   |
| Movement Report              | <code>movements</code>           | <code>created_at</code>            | filter <code>reversed != true</code> | TenantCollection          | OK; some old reversed entries may not have the flag                  |
| Customer Balance Report      | <code>customers.balance</code>   | n/a                                | n/a                                  | TenantCollection          | DRIFT (H-3)                                                          |
| Customer Receivables Summary | <code>invoices</code> aggregated | <code>order_date / due_date</code> | excludes voided                      | TenantCollection          | better than <code>customers.balance</code> , recommend authoritative |
|                              | <code>daily_sales_log</code>     | <code>date</code>                  |                                      | branch                    | OK                                                                   |

| Report                 | Source                                                      | Date Field                 | Voided handling                        | Branch/Tenant Filter | Reliability                                            |
|------------------------|-------------------------------------------------------------|----------------------------|----------------------------------------|----------------------|--------------------------------------------------------|
| Cashier Report         |                                                             |                            | excludes voided                        |                      |                                                        |
| Z-Report               | <code>daily_closings</code> + <code>wallet_movements</code> | <code>date</code> (branch) | tagged<br>late_encode + voided handled | branch               | OK                                                     |
| Daily Close Report     | <code>daily_closings</code>                                 | <code>date</code>          | OK                                     | branch               | OK                                                     |
| Void/Refund Report     | needs verification                                          | <code>voided_at</code> ?   | n/a                                    | TBD                  | low — minor                                            |
| Purchase Report        | <code>purchase_orders</code>                                | <code>order_date</code>    | OK                                     | branch               | OK                                                     |
| Backdated Entry Report | DOES NOT EXIST                                              | —                          | —                                      | —                    | <b>Gap — build for backdated credit reconstruction</b> |
| Audit Log Report       | <code>audit_log</code>                                      | <code>created_at</code>    | n/a                                    | TenantCollection     | OK                                                     |
| Discount Audit Report  | <code>discount_audit_log</code>                             | <code>created_at</code>    | excludes voided invoices               | OK                   | OK                                                     |

## 17. Duplicate / Dead Code Audit

| Item                                                                                                                                                                       | Action                                                                                                                     |
|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------|
| <code>pages/SalesPage.js</code> (legacy <code>/sales</code> ) vs <code>UnifiedSalesPage</code> ( <code>/sales-new</code> , <code>/pos</code> , <code>/sales-order</code> ) | <b>Remove</b> <code>SalesPage.js</code> , redirect <code>/sales</code> → <code>/sales-new</code> (already in user backlog) |
| <code>pages/PaymentsPage.js</code> vs <code>pages/AccountsPage.js</code>                                                                                                   | review for overlap                                                                                                         |
| <code>pages/UploadPage.js</code> vs <code>pages/DocUploadPage.js</code>                                                                                                    | review for overlap                                                                                                         |
| <code>routes/admin_backfill_240.py</code>                                                                                                                                  | one-shot migrations — keep but rename / move to <code>routes/admin_backfills.py</code> and add a manifest                  |
| <code>backend_test.py</code> (root level)                                                                                                                                  | older test; check if subsumed by <code>backend/tests/*</code>                                                              |
| <code>generate_test_report.py</code> (73KB)                                                                                                                                | one-shot script; move to <code>scripts/</code>                                                                             |
| <code>generate_audit_report.py</code> (21KB at backend root)                                                                                                               | one-shot; move to <code>backend/scripts/</code>                                                                            |
| 11 hardcoded-date unit test failures                                                                                                                                       | Pre-existing per handoff                                                                                                   |

## 18. Existing Audit / Test File Review

| File                                           | Status                                                                                      |
|------------------------------------------------|---------------------------------------------------------------------------------------------|
| <code>AgriBooks_Feature_Test_Report.pdf</code> | feature checklist — broadly positive; auth + sales + close path covered; no atomicity tests |



| File                                               | Status                                                                   |
|----------------------------------------------------|--------------------------------------------------------------------------|
| AgriBooks_Full_System_Audit_Report.pdf             | older audit — issues largely about UI; back-end risk surface NOT covered |
| AgriBooks_SaaS_Test_Report_v2.pdf                  | tenant-isolation + plan limits — well covered                            |
| test_result.md                                     | sparse, mostly green                                                     |
| backend/tests/test_full_system_audit.py            | tests cross-tenant isolation but does NOT test idempotency races         |
| backend/tests/test_unclosed_days_92.py             | hardcoded dates — part of P0 11-fail set                                 |
| backend/tests/<br>test_cross_tenant_privacy_180.py | useful baseline; should be expanded with the new H-5 / C-1 cases         |

## 19. Recommended Fix Plan

### Phase 1 — Critical Safety Fixes (ship in next deploy)

- C-1:** Stop shipping plain-text PINs in `/api/sync/pos-data`. Replace `offline_pin_grants` with a per-PIN `bcrypt_hash` + verifier metadata; client can `bcrypt.compare()` locally without ever seeing the plain PIN. Remove `admin_pin_hash` exposure or move it behind a higher-tier role.
- C-2:** Auth-gate `/api/setup/reset` to super-admin token + email-confirmation token; or remove from production builds.
- C-3:** Block `/api/admin-auth/setup-totp` for any super-admin who has `last_admin_login` set; require an out-of-band recovery code or signed email link.
- C-4 / C-5 / C-6:** Re-order sync paths to *insert invoice first, mutate inventory + AR + wallet only after success*; check `update_one(...).modified_count` everywhere; add unique index on `(branch_id, invoice_number)` once duplicates are scanned.
- C-7:** Fix `current_balance` → `balance` in `routes/sync.py:437`.
- C-8:** Replace RMA `count_documents+1` with `_raw_db.counters` atomic counter, key= `{org_id}:{branch_id}:RMA`; backfill any pre-existing duplicates.
- C-9:** `record_invoice_payment` and `accounting.receive_customer_payment` must reject `inv.status == "voided"`.
- CORS allowlist enforced in production; refuse to start if `CORS_ORIGINS` is empty/ `*` outside dev.

### Phase 2 — Business Logic Consistency (next 1–2 cycles)

- H-1:** Replace `replace_one` in draft finalization with explicit `update_one` of allowed fields + `find_one_and_update` guard on `status="for_preparation"`.
- H-3:** Build a `customers.balance` reconciliation report — for every customer, compare stored balance against ledger-derived balance from `invoices` + `payments[]` + `returns.credit_applied_to_invoices`. Flag drift > ₱0.50 for manager review.
- H-4:** Restrict return credit application to the linked invoice only by default; add a separate "Apply to other open invoices" UI that requires manager approval per row, written to a distinct audit row.
- H-11:** Build the **Historical Credit Encoding** workflow per §6 above. **This is the user's #1 outstanding business case.**
- H-12:** Offline negative stock now creates an `incident_ticket` + admin notification + `offline_reconciliation_queue` entry.
- H-5 / H-6 / H-7 / H-8:** Tighten `assert_branch_access`, force CORS allowlist, shorter JWT + refresh, validate `payload.org_id == user.organization_id`.
- H-9 / H-10:** Add unique compound indexes; backfill scan first.
- H-13:** Setup re-init guard should refuse if any `organizations` doc exists.

9. **H-14:** All admin backfill endpoints require manager+admin PIN combo + per-call audit row signed by user\_id; idempotency stamps already exist ( `iter240_backfill_at` ).

## Phase 3 — Cleanup & Deduplication

1. Remove `pages/SalesPage.js` ; redirect `/sales` → `/sales-new` (user backlog).
2. Move root-level `backend_test.py` , `generate_test_report.py` , `generate_audit_report.py` to `backend/scripts/` or `scripts/` .
3. Consolidate uploads pages.
4. Move all transient one-shot backfill endpoints behind a dedicated `/api/admin/backfills/*` namespace + PIN.
5. Standardize date-field convention: every report-style endpoint declares which of `order_date` | `created_at` | `payment.date` | `closed_at` | `encoded_at` it uses, in code comments and docs.

## Phase 4 — Tests and Guardrails

Add focused tests for: 1. Cash sale deducts stock once. 2. Credit sale deducts stock once and increases AR; void reverses both. 3. Payment reduces AR but never touches stock; voided invoice rejects payment. 4. Sale void restores stock and reverses each `payment[]` from its source wallet. 5. Partial return restores only returned qty. 6. Backdated credit AFTER `last_count_sheet` allowed; BEFORE blocked unless admin approves. 7. Offline sync replay (same `envelope_id` × N) → exactly one inventory move. 8. Concurrent offline sync (parallel POSTs, same `envelope_id`) → exactly one inventory move (proves race). 9. Branch A user cannot read Branch B inventory. 10. Tenant A cannot read Tenant B data via any route. 11. Cashier cannot void/refund/backdate via direct API call without permission/PIN. 12. Invoice correction does not double-deduct. 13. Drafts and parked sales do not deduct inventory. 14. Returns do not duplicate refunds. 15. Repack: parent-stock movement balances child-stock derivation across N concurrent sales. 16. RMA generator under 50 concurrent return inserts produces 50 unique numbers. 17. `/api/sync/pos-data` does not return any plain-text PIN field (regression test for C-1). 18. `/api/setup/reset` returns 401/403 without super-admin auth (regression test for C-2). 19. `/api/admin-auth/setup-totp` rejects when super-admin has prior `last_admin_login` (regression test for C-3). 20. `customers.balance` ledger-reconciliation invariant after a randomized fuzzed sequence of (sale, payment, return, void, partial-payment, interest accrual).

---

## 20. Test Plan (Required After Fix)

---

Every Phase-1 fix must ship with: - A regression test reproducing the original defect. - A fuzz test that runs 100+ randomized sequences (sale → payment → return → void → ...) and asserts the ledger invariants. - A sync-replay test with simulated network jitter (`asyncio.gather` of 10 retries with same `envelope_id`) asserting exactly-once inventory move.

---

**End of audit.** No code changes were applied. Awaiting prioritization decision before any implementation.